adesso

# AttackAI

**Die Schlagkraft eines Angreifers.**
Unter Ihrer Kontrolle.

KI-gestütztes Penetrationstest-Framework von adesso

ILLUSTRATIVES SZENARIO · EINE NACHT · KEIN MENSCH AM STEUER

```
22:04  › Aufklärung gestartet: Hosts, Dienste, Endpunkte
23:17  › Informationsleck in einer Fehlermeldung gefunden
00:52  › Anmeldung umgangen
02:30  ▸ Zugriff auf fremde Kundendaten
03:46  ▸ Rechteausweitung: Administrator
04:12  ▸ Ziel erreicht. Sie schlafen noch.
```

# Ein Angreifer braucht keine Bürozeiten.

Er braucht nur eine Lücke, die Ihr letzter Test nicht erreicht hat.

DIE UNBEQUEME WAHRHEIT

# Ihre Systeme werden getestet. Jeden Tag. Nur nicht von Ihnen.

Die einzige Frage ist, wer Ihre Lücke zuerst findet:

**Er oder Sie.**

# Ihr Pentest hat ein paar Tage. Ein Angreifer hat unbegrenzt Zeit.

AUTOMATISIERTER SCANNER

## Schnell, aber oberflächlich

- Prüft gegen bekannte Signaturen
- Verkettet Befunde nicht zu Angriffspfaden
- Erzeugt viele False Positives

DIE LÜCKE DAZWISCHEN

## Hier greifen echte Angreifer an

- Verkettete Schwachstellen
- Fehler in der Business-Logik
- Angriffspfade über mehrere Schritte

KLASSISCHER MANUELLER PENTEST

## Tief, aber zeitlich begrenzt

- Erfahrene Pentester sind rar und teuer
- Testfenster von wenigen Tagen
- Nicht jeder Endpunkt wird erreicht

**AttackAI schließt diese Lücke:** die Denkweise eines Pentesters mit der Ausdauer einer Maschine.

DER REALITÄTSCHECK

# Ihr Scanner meldet: alles im grünen Bereich.

Ein Angreifer liebt diesen Satz. Er verkettet genau das, was Ihr Scanner

**für harmlos hält.**

# AttackAI ist eine Cyber-Waffe.

Es greift real an: mit denselben Techniken, Werkzeugen und Zielen wie ein echter Angreifer.

**Der Unterschied liegt nicht in der Wirkung, sondern in der Kontrolle.**

# AttackAI simuliert keinen Angriff. Es führt ihn aus, bis zum Systemzugriff.

**BEISPIEL EINER ANGRIFFSKETTE**

**01**
**Informationsleck**
für sich harmlos

→

**02**
**Umgehung der Anmeldung**
Tür ins System

→

**03**
**Zugriff auf fremde Daten**
Daten erreichbar

→

**04**
**Rechteausweitung**
volle Auswirkung

### Echte Ausnutzung

Weist die tatsächliche Auswirkung nach, nicht nur ein passendes Muster.

### Eigene Exploits

Entwickelt Nachweise auch für unbekannte Lücken wie Zero-Days.

### Denken in Ketten

Verbindet Einzelfunde bis zu Systemzugriff und Rechteausweitung.

### Rund um die Uhr

Prüft autonom, bis zwei Runden nichts Neues mehr bringen.

# Scanner melden Muster, Pentester haben Termine. AttackAI greift durchgehend an.

| Kriterium | Automatisierter Scanner | Manueller Pentest | AttackAI |
|---|---|---|---|
| **Prüftiefe** | Signatur-/Musterabgleich | Hoch, abhängig vom Tester | **Hoch, systematisch und wiederholt** |
| **Verkettung zu Angriffspfaden** | Nein | Ja | **Ja** |
| **Suche nach unbekannten Lücken** | Nein | Teilweise | **Ja, inklusive 0-Days** |
| **Testdauer** | Minuten, jederzeit | Tage, terminlich begrenzt | **Durchgehend für die vereinbarte Dauer** |
| **False-Positive-Rate** | Hoch | Niedrig | **Niedrig, jeder Fund verifiziert** |
| **Sichtbare Testabdeckung** | Kaum | Abhängig vom Bericht | **Ausdrücklich ausgewiesen** |
| **Nachweisführung** | Automatisiert generiert | Manuell dokumentiert | **Mit Reproduktionsschritten** |

DAS TEAM

# 25 Angreifer. Keine Mittagspause. Kein Feierabend.

Ihr Pentest-Team geht nach ein paar Tagen nach Hause. AttackAI testet, bis

**nichts Neues mehr auftaucht.**

# 25 KI-Agenten: einer steuert, 15 greifen an, neun überwachen jeden ihrer Schritte

**1 Orchestrator** koordiniert alle Agenten, steuert die Phasen und hält die Leitplanken jederzeit ein

## 15 Agenten greifen an

Aufklären, planen, ausnutzen

**AUFKLÄRUNG**

- Aufklärer
- Host-Audit
- OSINT-Rechercheur
- KI-Aufklärer
- Exploit-Rechercheur
- Quellcode-Analyst
- Produkt-Code-Auditor

**PLANUNG**

- Angriffsplaner

**ANGRIFF**

- Web-/API-Angreifer
- Netzwerk-Angreifer
- KI-Angreifer
- Exploit-Entwickler
- Credential-Stratege
- Interaktions-Detektor
- Post-Exploitation-Spezialist

## 9 Agenten greifen nicht an

Validieren, steuern, zurückbauen

**PRÜFUNG**

- Schwachstellen-Validierer
- KI-Validierer

**STEUERUNG**

- Abdeckungs-Prüfer
- Lauf-Beobachter
- Blockade-Löser
- Operator-Stellvertreter

**SICHERUNG & ABSCHLUSS**

- Scope-Wächter
- Bereiniger
- Berichterstatter

DIE GEWISSENSFRAGE

# Würden Sie einer KI erlauben, Sie anzugreifen?

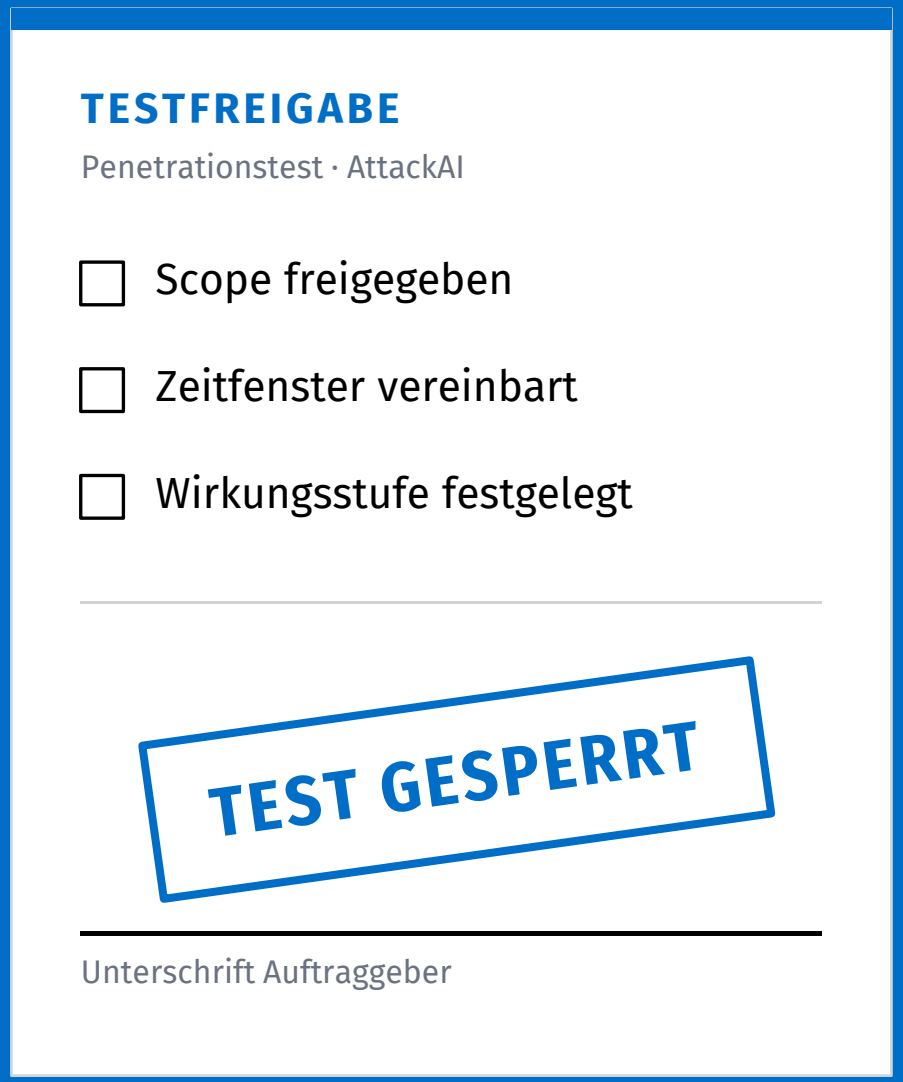
Ein Angreifer fragt nie. AttackAI fragt vor jedem riskanten Schritt:

**Darf ich?**

# Ohne Ihre Unterschrift passiert: nichts.

Vor dem ersten Paket prüft AttackAI Testfreigabe, Scope und Zeitfenster. Fehlt eines davon oder ist es abgelaufen, startet der Test nicht.

**Dieser Check ist ein Tor, kein Arbeitsschritt.**



# Sieben Sperren. Fällt eine weg, fällt der Angriff aus.

**01 Kein Einsatz ohne Freigabe**
Ohne signierte Testfreigabe, Scope und Zeitfenster startet kein Test.

**02 Scope ist absolut**
Systeme außerhalb werden dokumentiert, aber nie angefasst.

**03 Wirkungsbegrenzung**
Die Härte ist vorab festgelegt, für Produktivsysteme gilt die vorsichtigste Stufe.

**04 Zwei-Schlüssel-Prinzip**
Riskante Schritte gibt der verantwortliche Pentester frei.

**05 Lückenlose Protokollierung**
Jede Aktion mit Zeitpunkt, Ziel, Werkzeug und Ergebnis.

**06 Rückbau als Pflicht**
Jede Änderung wird registriert und am Ende zurückgenommen.

**07 Not-Aus**
Ein Wächter-Agent stoppt jede Grenzüberschreitung, der Lauf ist jederzeit anhaltbar.

**Nie unbeaufsichtigt**
Jeder Lauf steht unter der Verantwortung eines benannten Pentesters.

# Sieben Aktionen sind grundsätzlich abgeschaltet, solange sie nicht schriftlich beauftragt sind

- ✖ **Keine Überlastungs- oder DoS-Tests**
  keine Angriffe auf die Verfügbarkeit
- ✖ **Kein Löschen oder Zerstören von Daten**
  keine unumkehrbaren Eingriffe
- ✖ **Keine Massen-Ausleitung von Daten**
  Nachweise nur exemplarisch, Kundendaten maskiert
- ✖ **Keine Persistenz, keine Hintertüren**
  kein Zugang überdauert den Test
- ✖ **Kein Social Engineering**
  keine Angriffe auf Mitarbeitende
- ✖ **Nichts außerhalb des Scopes**
  ausnahmslos
- ✖ **Keine Selbstverbreitung**
  AttackAI verlässt die freigegebene Umgebung nicht

NICHT UMLENKBAR

## Ein Zielsystem kann die Waffe nicht gegen Sie wenden

- Alles, was AttackAI vom Ziel liest, ist Analysematerial, niemals Anweisung.
- Kein platzierter Text kann den Scope erweitern oder eine Leitplanke abschalten.
- Taucht solcher Text auf, wird er selbst als Befund berichtet.

# Sechs Phasen. Am Ende ist alles wieder so, wie es war.

**FREIGABE-TOR** | **RUNDE FÜR RUNDE**

1 **Vorbereitung**
Freigabe, Scope und Zeitfenster prüfen. Ohne Signatur kein Test.

2 **Aufklärung**
Angriffsfläche der freigegebenen Systeme erfassen.

3 **Planung**
Die stärksten Angriffspfade zuerst priorisieren.

4 **Aktive Prüfung**
Iterativ ausnutzen, bis nichts Neues mehr auftaucht.

5 **Validierung**
Jeden Fund verifizieren, Bericht erstellen.

6 **Rückbau**
Änderungen zurücknehmen, Ausgangszustand prüfen.

**Live-Transparenz:** Fortschritt, Testabdeckung und Freigaben sind während der Prüfung live einsehbar.

DAS ERGEBNIS

# Ein echter Angreifer schreibt Ihnen keinen Bericht.

Von ihm erfahren Sie es aus der Presse. Von AttackAI vorher, mit

**Nachweis und Handlungsempfehlung.**

# Am Ende wissen Sie schwarz auf weiß, was ein Angreifer erreicht hätte

**INHALT DES BERICHTS**

**01** **Management-Zusammenfassung**
Die Gesamtlage auf einen Blick

**02** **Befunde nach Schweregrad (CVSS 4.0)**
Mit Auswirkung, Reproduktionsschritten und Empfehlung

**03** **Nachweis zu jedem Fund**
Nachvollziehbar und behebbar, ohne Kundendaten im Klartext

**04** **Ehrliche Testabdeckung**
Was geprüft wurde und was nicht erreicht werden konnte

**Optional:** vollständiges Prüfprotokoll jeder einzelnen Aktion

**EINSATZSZENARIEN**

**Web-Anwendungen & APIs**
Zugriffskontrolle, Injection, SSRF/IDOR, Business-Logik

**Netzwerk & Infrastruktur**
Dienste, Protokolle und Active-Directory-Umgebungen

**Whitebox und Greybox**
Ergänzende Quellcode- und Konfigurationsanalyse

**Retest**
Prüft, ob ein Fix wirklich greift

# **Der reale Angriff.** Ohne den realen Schaden.

**Tiefe statt Oberfläche**
Echte Ausnutzung und verkettete Angriffspfade

**Ausdauer statt Zeitdruck**
Iterativ geprüft, mit ausgewiesener Abdeckung

**Kontrolle bei Ihnen**
Kein Schritt ohne Freigabe, jederzeit anhaltbar

**Datenschutz eingebaut**
Maskierung vor jeder KI-Verarbeitung

## Nächster Schritt: Live-Demo vereinbaren

**Jan Hill · adesso Public Sector**
jan.hill@adesso.de
**Tim Jambor · adesso Cyber Offensive Team**
tim.jambor@adesso.de